

مراجعة معمارية: ال Backend مع السيرفر

منصة SaaS — Daari عراقية متعددة المستأجرين · توصيل مياه الشرب · Phi-Bit

السيرفر: 45.84.138.119 · Contabo VPS (مشارك) المكدس: BullMQ · Redis · PostgreSQL+PostGIS · NestJS 10 التاريخ: 03-06-2026

الحكم المختصر

✓ التصميم صحيح لمرحلته

نعم، التصميم صحيح وجيد الحكم لمرحلته (منتج مبكر، منطقة واحدة، فريق صغير). هو monolith نظيف بـ NestJS على عقدة systemd واحدة مُحسنة، والأجزاء الصعبة مُنقّدة بشكل صحيح فعلاً. القرار بتجّيب Docker/k8s/HA/microservices هو «تبسيط مقصود وصحيح» وليس قصوراً.

التحفظ الوحيد: ثغرة تشغيلية شبه مؤكدة لفقدان البيانات + فجوات تعافي من الكوارث (DR) رخيصة الإصلاح، يجب إغلاقها قبل أن تتراكم بيانات حقيقية. أي: المعمارية سليمة، والمطلوب نظافة تشغيلية لا إعادة تصميم.

✓ ما هو صحيح فعلاً (قرارات تستحق الإبقاء)

- عزل المستأجرين (multi-tenant) دفاع متعدد الطبقات — أهم خاصية في المنتج، ومُنقّدة بشكل صحيح: TenantGuard
- عام يستخرج tenantId من ال JWT (لا من العميل أبداً) و كل استعلام Prisma يُضيف tenantId في where مستقلاً. ملكية الزبون/السائق مربوطة بهويته (customer.userId === user.id) — ما يُغلق ثغرة IDOR الأفقية الكلاسيكية.
- المصادقة فوق المستوى المطلوب: Argon2id بمعايير OWASP، والتطبيق يرفض الإقلاع في الإنتاج بسرّ JWT ضعيف/مفقود، توكنات وصول 15 دقيقة، و refresh tokens مُعمّاة في قاعدة البيانات مع تدوير وإبطال — أفضل من JWT موقع.
- صحة مالية تحت التزامن: إتمام الطلب يحدّث الرصيد + الخزان + المخزون + المحفظة داخل transaction \$ حقيقي، والمبالغ تُخزّن ك Int (دينار) لا Float .
- طبقة بيانات واعية للحجم دون مبالغة: فهارس مركّبة على المسارات الساخنة (tenantId, status) / (tenantId, createdAt) ، صفحات مُقيّدة بـ take ، تجميعات لوحة التحكم بـ Promise.all .
- الكاش والطوابير مُخرّجة خارجياً وآمنة أفقياً مسبقاً (Redis + BullMQ) بمفاتيح مفصولة لكل مستخدم/مستأجر، وإعادة محاولة مع (backoff).
- أمان التعايش على VPS المشترك = الخاصية الأبرز: سكريبتات النشر تتحقّق من /root/PROJECTS.md ، وتقصّر rsync --delete على شجرة daari-water-* ، ولا تعيد تشغيل خدمات غيرك، ولا تلمس nginx vhosts الأخرى. وحدة

systemd مُحَصَّنَة (`MemoryMax` ، `NoNewPrivileges` ، `ProtectSystem=strict`).

- **خط أساس تشغيلي حاضر:** `/health` (liveness) و `/ready` (SELECT 1 فعلي)، تسجيل pino مع حجب الأسرار، Sentry، نسخ احتياطي ليلي، واستخدام `db push` (وليس `migrate deploy` الذي سيُنشئ صفر جداول على هذا المستودع).

المخاطر الحقيقية (بعد التحقق العكسي — جوهرية فقط)

(1) خطر عالي `deploy.sh api` يمسح ملفات الإنتاج عند كل نشر ⚠️ (تم التحقق مباشرة)

في `deploy/deploy.sh:61-67` : `rsync -avz --delete` يُزامن إلى `/var/www/daari-water-api/` مع استثناءات لـ `node_modules/.env/.git` فقط. لكن `UPLOADS_DIR=/var/www/daari-water-api/uploads` (مضطرّ أن يكون داخل هذه الشجرة لأن `ProtectSystem=strict` يجعل المسار الافتراضي `/var/uploads` للقراءة فقط). والمستودع المحلي لا يحوي مجلد `uploads/` → ف `--delete` يحذف كل صور إثبات التسليم والتقارير عند كل نشر للـ `backend`.
لماذا يهّم: فقدان متكرّر شبه مؤكد لـ «أدلة التسليم» (للنزاعات والاحتيايل). النسخة الاحتياطية تحفظ `proofPhotoUrl` في القاعدة لكن ليس البايتات → روابط تشير إلى 404.

الإصلاح: سطر واحد — إضافة `--exclude uploads` لأمر `rsync` (أو نقل `UPLOADS_DIR` خارج الشجرة المُزامنة).

(2) خطر عالي **التعافي من الكوارث غير مُختبر، والملفات غير منسوخة**

نسخة `pg_dump` ليلية موجودة، لكن لا يوجد دليل استرجاع (`restore runbook`) في المستودع، ولم يُجرب الاسترجاع أبداً، والنسخ يغطي `uploads/` مجلد Postgres فقط — مجلد `uploads/` لا يُنسخ إطلاقاً. مع `db push` (لا `rollback` للسكينة)، الاسترجاع-من-`dump` هو مسار التعافي الوحيد وهو الأقل اختباراً. النظام يحمل أموالاً (أرصدة، محافظ، فواتير، رواتب).

الإصلاح: بعد ظهر واحد — اكتب `deploy/RESTORE.md` ، نَقِّد استرجاعاً تجريبياً إلى قاعدة `daari_water_restore` ، وأضيف `uploads/` للنسخ الليلي.

(3) خطر عالي **النسخة الخارجية (S3) تتعطل بصمت**

`scripts/backup-db.sh:60-70` يتخطى رفع S3 إن غابت المفاتيح أو `aws-cli` ويخرج بـ 0 . القالب يشحن مفاتيح S3 فارغة. فالحالة الافتراضية: 7 أيام نسخ محلية على نفس قرص القاعدة على عقدة واحدة — أي سيناريو فقدان القرص يحو القاعدة وكل نسخها معاً.

الإصلاح: اجعل تخطي S3 صاخباً (تنبيه Sentry / خروج غير صفري) + `dead-man's-switch` في `bootstrap` (`UptimeRobot/healthchecks.io`) + تثبيت `aws-cli` في `bootstrap`.

مخاطر متوسطة / منخفضة (مُخَفَّضة بعد التحقق)

متوسط `Redis` مشترك بلا كلمة مرور وبلا `keyPrefix /index db` عبر 4 مشاريع → ليس تسريباً (`loopback`)، بل خطر إتاحة: `FLUSHALL` من مشروع مجاور قد يُسقط مهام WhatsApp المقبولة. **الإصلاح:** سطران — `db` مخصّص + `keyPrefix: 'daari:'`.

متوسط `DriverLocation` **ينمو بلا تقليم** → `50~80MB/شهر` (مشكلة أرباع سنة لا أسابيع)، لكن نمو قرص غير محدود على VPS مشترك. **الإصلاح:** `@Cron` يومي يحذف ما قبل 60-90 يوماً (20~ سطر).

متوسط `prisma db push` بلا `migrations` → التحقق أثبت أن الفقدان الكارثي محميّ عملياً (لا `--accept-data-loss` ، وSSH، `heredoc` بلا `stdin` يُجهّز النش). التكلفة الحقيقية = الصيانة. **الإصلاح:** خطّط للتحوّل إلى `migrate deploy` قبل أول تغيير غير-إضافي على بيانات حقيقية.

قائمة الإجراءات المُرتّبة

🔥 يجب الآن — هذا الأسبوع (ساعات عمل)

- أضف `--exclude uploads` في `deploy/deploy.sh` — سطر واحد ضد فقدان متكرر.
- اكتب `deploy/RESTORE.md` ونفذ استرجاعاً تجريبياً واحداً.
- أضف `uploads/` للنسخ الليلي.
- اجعل تخطّي S3 صاخباً `heartbeat +`.
- تأكد أن `SENTRY_DSN` مضبوط فعلياً وأن UptimeRobot يفحص `/ready`.

● قريباً

- عزل Redis (`db` + `keyPrefix`).
- تقليم `DriverLocation` دورياً.
- التخطيط للتحوّل إلى `prisma migrate`.
- `enableShutdownHooks()` + `TimeoutStopSec` لإغلاق رشيق.
- اختبارات للحالات المالية (إتمام/استرجاع/رواتب) كبوابة قبل النشر.

● يصحّ تأجيله

- التوسّع الأفقي / العقدة الثانية (موثقاً كـ«عقدة واحدة فقط»).
- نقل الملفات إلى S3 كمخزن أساسي.
- HA / read replica / تعدّد المناطق.
- Redis adapter socket.io (لا gateway بعد).

السؤال الاستراتيجي الأكبر

ثلاثي (VPS مشترك + `db push` بلا `migrations` + عقدة واحدة بملفات على القرص المحلي) — هل هو الأساس الصحيح طويل المدى؟ نعم، هو الأساس الصحيح الآن ولمرحلة التجربة المنظورة. لكنّ الثلاثة مترابطة بطريقة تُزيل شبكات الأمان التي تلتقط الخطأ عادةً: تغيير سكيمة سيئ بلا rollback، والاسترجاع الوحيد لم يُختبر، والملفات الأهم تُحذف عند كل نشر ولا تُنسخ.

الحركة الصحيحة ليست إعادة المنصة — بل شراء شبكات الأمان رخيصاً وعلى جدول: أغلق ثغرات DR/الملفات هذا الأسبوع، وتبنّ `prisma migrate` قبل أول تغيير غير-إضافي، ووثّق ثابت «عقدة واحدة». المعمارية تكتسب حقّها في البقاء بسيطة عبر جعل قصة تعافيتها جديرة بالثقة.

